

WEEK 5: ENUMERATION - LAB ACTIVITIES

Complete Step-by-Step Lab Activities Guide

Covers Local & Remote Enumeration
Windows & Linux Systems

Table of Contents

- Lab Overview & Prerequisites
- Lab 1: Windows Local Enumeration
- Lab 1a: Understanding NetBIOS Suffixes
- Lab 2: NBTscan Computer Discovery
- Lab 3: SMB Share Enumeration
- Lab 3a: NULL Session Exploitation
- Lab 4: Linux Local Enumeration
- Lab 5: SNMP Enumeration
- Lab 6: NFS Share Enumeration
- Lab 7: LDAP Directory Enumeration
- Lab 8: Create Enumeration Cheat Sheet
- Troubleshooting Guide
- Quick Reference Table

Lab Overview & Progression

These labs take you through a complete enumeration workflow from local system assessment to remote discovery.

Lab Sequence

- Labs 1-1a: Windows Local → Understanding output
- Labs 2-3: Windows Remote → Discovery → Share access
- Lab 3a: Advanced Windows → NULL session vulnerability
- Lab 4: Linux Local → Finding escalation vectors
- Labs 5-7: Linux Remote → SNMP, NFS, LDAP enumeration
- Lab 8: Documentation → Professional cheat sheet

Prerequisites

- ✓ Kali Linux installed on Windows/macOS with internet connectivity
- ✓ Windows 10/11 VM running (target for labs 1-3)

- ✓ Metasploitable 2 or 3 VM available (target for labs 4-7)
- ✓ NAT network adapter configured (from Week 1)
- ✓ All tools are pre-installed in Kali

=====

LAB 1: Windows Local Enumeration

- Duration: 15 minutes | Difficulty: Beginner
- Objective: Gather system information from WITHIN a Windows system
- Target: Any Windows 10/11 system you have access to

Why This Matters

In penetration testing, once you compromise a Windows system (via phishing, an exploit, etc.), the FIRST step is to gather local information. This determines:

- What version of Windows - what exploits apply
- What patches are missing - what vulnerabilities exist
- What services are running - which might be exploitable
- Who are the admins - who have more privileges than we do?
- What security is present - what will detect us

Key Definitions

Hotfix: A patch/update to fix security or stability issues (identified by KB numbers)

- Service: A program running continuously with SYSTEM privileges
- Unquoted Service Path: Path without quotes containing spaces - vulnerable!
- Local User: Account on this specific computer (not domain)
- Admin Group: Users in this group have administrative privileges

STEP-BY-STEP INSTRUCTIONS

Step 1: Get OS Version and Patches (5 minutes)

ACTION 1: Open Command Prompt

Windows 10/11: Press Win+R, type “cmd”, press Enter or click Start, search for “Command Prompt”

ACTION 2: Run the systeminfo command

Type exactly: `systeminfo`

Press Enter and wait 2-3 seconds for output

SCREENSHOT 1: Take a screenshot of the entire systeminfo output

WHAT YOU’LL SEE:

- OS Name: e.g., “Microsoft Windows 10 Enterprise”
- OS Version: e.g., “10.0.19045”
- System Boot Time: when the computer was last restarted
- Hotfix(s): patches installed - look for “KB” followed by numbers
- Total Physical Memory: how much RAM

💡 *ATTACKER PERSPECTIVE:*

- Attackers look for: Missing patches = known vulnerabilities
- Few hotfixes = system is vulnerable to known exploits
- Old OS version = many more exploits available

ALTERNATIVE METHOD: Using WMI

Type: `wmic qfe list brief`

Shows: Patches in a cleaner table format

Step 2: Enumerate Running Services (5 minutes)

ACTION 3: List all services

Type: `sc query`

⚠️ OUTPUT WILL BE LONG - this is normal! Services scroll through.

To save to a file instead (easier to analyze):

Type: `sc query > services.txt`

Then: `notepad services.txt` (to open in Notepad)

SCREENSHOT 2: Show some running services

WHAT TO LOOK FOR:

- STATE: RUNNING - services currently active
- STATE: STOPPED - services not running
- Unusual service names - might be installed malware!

ACTION 4: Get service executable paths (CRITICAL!)

It shows WHERE services are located - can identify privilege escalation.

Type this exactly:

➤ `wmic service get name,displayname,pathname,startmode`

It shows service names and their executable paths.

SCREENSHOT 3: Capture the table output

WHAT TO LOOK FOR - UNQUOTED SERVICE PATHS:

- **VULNERABLE:** C:\Program Files\My Service\service.exe
- **SAFE:** "C:\Program Files\My Service\service.exe"

If the path has spaces and NO quotes = privilege escalation vector!

Step 3: Enumerate Local Users (3 minutes)

ACTION 5: List all users on the system

Type: `net user`

SCREENSHOT 4: Show user list

Get detailed info on a specific user:

Type: `net user Administrator`

Shows: Last login, password age, group membership

Step 4: Check Administrator Group (2 minutes)

ACTION 6: Who has admin rights?

Type: `net localgroup Administrators`

Step 5: Security Software

Check antivirus:

➤ `sc query windefend`

Check firewall:

➤ `netsh advfirewall show currentprofile`

SCREENSHOT 5: Show Administrators group members

💡 *ATTACKER THINKING:*

- These users can do ANYTHING on the system
- If we can steal their credentials, we get full control

Lab 1 Deliverables

Document the following in your assignment:

- OS version and build number (from systeminfo)
- Count of hotfixes installed
- List of 5-10 running services

- Any unquoted service paths (if found)
- All local user accounts
- Members of the Administrators group
- 5 screenshots with captions (Screenshots 1-5 from above)

ANALYSIS REQUIRED:

- Write 2-3 sentences on: Is this system well-patched? Why or why not?
- Write 2-3 sentences on: How many admins? Is this normal?

=====

LAB 1a: Understanding NetBIOS Suffixes

- Duration: 10 minutes | Difficulty: Beginner
- Objective: Understand what NetBIOS codes mean in network enumeration
- Prerequisite: Complete Lab 1 first

Why This Lab?

- When you run network discovery tools like `NBTscan`

You will see cryptic codes like *MYCOMPUTER<00>*, *<20>*, or *<1C>*. These codes tell you EXACTLY what services are running on a computer!

Understanding them makes you understand your target better.

NetBIOS Code Reference

MOST IMPORTANT:

<00> = Workstation (normal computer)

<20> = Server (FILE SHARING ENABLED!) ★ MOST DANGEROUS

<1C> = Domain Controllers (stores user passwords) ★ HIGH VALUE

OTHER CODES:

- <01> = Master Browser (network discovery)
- <03> = Messenger Service
- <06> = RAS Server (remote access)
- <1B> = Domain Master Browser
- <1D> = Master Browser
- <1E> = Browser Elections

STEP-BY-STEP

Step 1: Look Up These Codes

```
➤ nbtscan 192.168.1.0/24
```

Note: Replace IP address. Use the reference above or the week 5 slides to understand each code

- <00> means the computer exists
- <20> means file sharing is ON
- <1C> means a domain controller with user data
-

Step 2: Create a Study Sheet

Write out all necessary codes and explain what each means. It will be helpful for Lab 2 (NBTscan).

Step 3: When You Run NBTscan (Lab 2)

You'll see output like:

192.168.1.100 PC-OFFICE<00> Workstation

192.168.1.101 SERVER-FILE<20> Server

192.168.1.102 DC-DOMAIN<1C> Domain Controller

NOW you'd understand what those codes mean!

Lab 1a Deliverable

- For your assignment, create a table:
- Column 1: NetBIOS Code (e.g., <00>, <20>, <1C>)
- Column 2: Meaning (what service)
- Column 3: Why It's Important (security implications)

=====

LAB 2: NBTscan Computer Discovery

- Duration: 10 minutes | Difficulty: Beginner
- Objective: Discover Windows computers on the network via NetBIOS
- Target: Windows system from Lab 1

What NBTscan Does

NBTscan sends NetBIOS requests to find Windows computers on a network.

It shows you computer names, IP addresses, and services running.

It's completely passive - no hacking, just discovery!

STEP-BY-STEP INSTRUCTIONS

Step 1: Open Terminal in Kali Linux

Click the Terminal icon in the taskbar or Right-click the desktop → Open Terminal Here

Step 2: Check if NBTscan is installed

Type: `which nbtscan`

If you see a path, it's installed (skip Step 3)

If no output, follow Step 3 to install

Step 3: Install NBTscan (if needed)

Type: `sudo apt-get install nbtscan`

Type: `y` (yes when asked)

Wait for the installation to complete

Step 4: Scan a Single Windows Computer

Replace 192.168.1.100 with YOUR Windows VM's IP

```
➤ nbtscan 192.168.1.100
```

Example output:

```
192.168.1.100 MYCOMPUTER<00> Workstation
```

```
192.168.1.100 MYCOMPUTER<20> Server
```

```
192.168.1.100 DOMAIN<1C> Domain Controller (if domain-joined)
```

SCREENSHOT 6: Capture NBTscan output

Step 5: Scan Your Network Range (Optional - if you have multiple Windows systems)

It scans the entire subnet

```
➤ nbtscan 192.168.1.0/24
```

(Replace 192.168.1.0/24 with your network range)

It will show ALL Windows computers on your network!

Lab 2 Deliverables

- NBTscan output showing discovered computers
- Screenshot of the scan results
- List of computers found with their IP addresses
- For each computer, note the services found (<00>, <20>, etc.)

=====

LAB 3: SMB Share Enumeration

- Duration: 15 minutes | Difficulty: Beginner
- Objective: List and access shared resources on Windows systems
- Target: Windows system discovered in Lab 2

What SMB Is

SMB (Server Message Block) is the protocol Windows uses for file and printer sharing.

When you connect to network drives in Windows, you're using SMB!

We use *smbclient* (a Linux tool) to enumerate these shares.

STEP-BY-STEP INSTRUCTIONS

Step 1: List Available Shares

Replace 192.168.1.100 with your Windows VM IP

```
➤ smbclient -L //192.168.1.100
```

WHEN PROMPTED:

- If asked for "Workgroup [WORKGROUP]": just press Enter
- If asked for a password: press Enter (empty password)

WHAT YOU'LL SEE:

- C\$ Default admin share (hidden - requires admin)
- IPC\$ Inter-process communication (hidden)
- ADMIN\$ Admin shares (hidden)
- Public Shared folder (visible if it exists)
- Users' Shared folder (visible if it exists)

SCREENSHOT 7: Capture list of shares

Step 2: Connect to an Accessible Share

Try Public first (if it exists)

```
➤ smbclient //192.168.1.100/Public
```

You'll see a prompt: `smb: \>`

Step 3: List Files in Share

Type: `ls`

Shows files in the share

Type: `cd dirname` (to enter subdirectory)

Type: `get filename` (to download a file)

SCREENSHOT 8: Show files in share

Step 4: Exit the Share

Type: `exit`

Back to the terminal prompt

Lab 3 Deliverables

- List of all shares found
- Which shares were accessible (could you connect to them)?
- Files found in accessible shares
- Screenshots of smbclient output (at least 2)
- Analysis: What sensitive information was exposed?

=====

LAB 3a: NULL Session Exploitation

- Duration: 10 minutes | Difficulty: Intermediate
- Objective: Extract information without any credentials
- **Note: Only works on Windows NT, 2000, XP. Modern Windows are protected.**

What is a NULL Session?

A connection using EMPTY username and EMPTY password.

It was a feature in older versions of Windows that allowed trusted domain communication. But it's also a CRITICAL VULNERABILITY!

STEP-BY-STEP

Step 1: Attempt NULL Session

From Kali terminal:

```
➤ net use \\192.168.1.100\IPC$ "" /u:""
```

If successful: "The command completed successfully."

If failed: "Logon failure" (system is protected - **normal for modern Windows**)

SCREENSHOT 9: Result of NULL session attempt

Step 2: If NULL Session Succeeded - Enumerate

Type: `net view \\192.168.1.100`

Shows: All shares on the target

Step 3: Extract Users (advanced)

Type: `enum4linux -u 192.168.1.100`

Shows: All users if a NULL session is active

Lab 3a Deliverables

- Document whether the NULL session was successful or not
- If successful: what information was extracted
- If not successful: explain why (system protection)
- Write analysis: Why is a NULL session dangerous?

=====

LAB 4: Linux Local Enumeration

- Duration: 15 minutes | Difficulty: Beginner
- Objective: Gather information from WITHIN a Linux system
- Target: Your Kali Linux system OR Metasploitable 2/3

Why Local Linux Enumeration?

After compromising a Linux system, gather local information to find:

- SUID binaries that might escalate privileges
- Vulnerable services running with high privileges
- User accounts (potential for lateral movement)
- Firewall rules (what network access is allowed)

STEP-BY-STEP INSTRUCTIONS

Step 1: Get Linux Version Information

➤ `uname -a`

Shows: Operating system and kernel version

Also try:

➤ `cat /etc/os-release`

Shows: Linux distribution name and version

SCREENSHOT 10: Version information

Step 2: Find SUID Binaries (CRITICAL!)

WHAT IS SUID?

SUID means: “Set User ID on execution” = Program runs with OWNER’s privileges, not the user who ran it. If the owner is root and there’s a vulnerability = INSTANT ROOT ACCESS!

Find all SUID binaries:

```
➤ find / -perm -u=s -type f 2>/dev/null
```

Note: “2>/dev/null” hides permission errors - makes output cleaner

SCREENSHOT 11: SUID binaries found

Step 3: Enumerate Services

```
➤ systemctl --type=service
```

Shows: All services and status

Look for: Unexpected services, old services (ssh, ftp, telnet)

SCREENSHOT 12: Services listing

Step 4: List All Users

```
➤ cat /etc/passwd
```

Shows: All user accounts on the system

Format: *username:password:UID:GID:description:home:shell*

SCREENSHOT 13: User accounts

Step 5: Check Firewall Rules (if present)

```
➤ sudo iptables -L -n
```

Shows: Current firewall rules

Lab 4 Deliverables

- Linux distribution and kernel version
- List of all SUID binaries found
- Running services (at least 10)
- All user accounts
- Firewall rules (if present)
- Analysis: Identify 3 potential privilege escalation vectors
- Screenshots: 5 screenshots (10-14)

=====

LAB 5: SNMP Enumeration (Remote)

- Duration: 15 minutes | Difficulty: Intermediate
- Objective: Query remote Linux system via SNMP for system information
- Target: Metasploitable 2/3 running Linux

What is SNMP?

SNMP (Simple Network Management Protocol) allows remote administration of network devices.

When enabled, it reveals system information via port 161 (UDP).

Default community string "public" allows unauthenticated access!

STEP-BY-STEP

Step 1: Check if SNMP is open

```
➤ nmap -p 161 192.168.1.X
```

(Replace X with Metasploitable IP last octet) If you see: "161/udp open snmp" - it's accessible!

Step 2: Install snmpwalk (if not installed)

```
➤ sudo apt-get install snmp snmp-mibs-downloader
```

Step 3: Perform SNMP Walk

This queries all available SNMP information:

```
➤ snmpwalk -c public -v 1 192.168.1.X
```

Shows: System name, uptime, running processes, installed software

SCREENSHOT 15: SNMP walk output

Step 4: Query Specific Information

Get system name:

```
➤ snmpwalk -c public -v 1 192.168.1.X 1.3.6.1.2.1.1.5
```

Lab 5 Deliverables

- Confirmation that SNMP port is open
- SNMP walk output (full or partial)
- System name discovered via SNMP
- System uptime
- Running processes if available
- Screenshots of SNMP queries (2-3)

=====

LAB 6: NFS Share Enumeration

- Duration: 15 minutes | Difficulty: Beginner
- Objective: Discover and mount NFS (Network File System) shares
- Target: Metasploitable 2/3 with NFS enabled

What is NFS?

NFS is the Linux equivalent of SMB file sharing.

It allows remote systems to mount directories as if they were local.

Many Linux systems expose NFS without proper permissions!

STEP-BY-STEP

Step 1: Check for NFS

```
➤ nmap -p 2049 192.168.1.X
```

If you see: "2049/tcp open nfs" - NFS is running!

Step 2: List NFS Shares

Install showmount if needed: `sudo apt-get install nfs-common`

```
➤ showmount -e 192.168.1.X
```

Shows: All exported NFS shares

SCREENSHOT 16: NFS shares listing

Step 3: Create Mount Point

```
➤ mkdir /tmp/nfs_mount
```

Step 4: Mount the NFS Share

Replace /home with the share name from Step 2:

```
➤ sudo mount -t nfs 192.168.1.X:/home /tmp/nfs_mount
```

Step 5: List Files in Mounted Share

```
➤ ls -la /tmp/nfs_mount/
```

Shows: Files in the NFS share (be careful - might contain sensitive data!)

SCREENSHOT 17: NFS share contents

Step 6: Unmount When Done

```
➤ sudo umount /tmp/nfs_mount
```

Lab 6 Deliverables

- Confirmation that NFS is open
- List of NFS shares available
- Files found in accessible shares
- Analysis: What sensitive files were exposed?
- Screenshots of showmount and mounted share (2-3)

=====

LAB 7: LDAP Enumeration

- Duration: 15 minutes | Difficulty: Advanced
- Objective: Query LDAP directory for users and groups
- Target: System with LDAP enabled (typically domain controller)

What is LDAP?

LDAP (Lightweight Directory Access Protocol) stores user and computer information.

In Windows domain environments, Active Directory uses LDAP.

Often exposed without authentication on port 389!

STEP-BY-STEP

Step 1: Check for LDAP

```
➤ nmap -p 389 192.168.1.X
```

If open: "389/tcp open ldap"

Step 2: Install ldap-utils (if needed)

```
➤ sudo apt-get install ldap-utils
```

Step 3: Basic LDAP Query

```
➤ ldapsearch -h 192.168.1.X -x -s base
```

Shows: LDAP server information

SCREENSHOT 18: LDAP query results

Step 4: Query for Users (if you find the Base DN)

Replace dc=example,dc=com with actual base DN:

```
➤ ldapsearch -h 192.168.1.X -x -b "dc=example,dc=com"
```

Lab 7 Deliverables

- Confirmation that LDAP port is open

- LDAP directory information retrieved
- Base DN of the directory
- Users found (if available)
- Screenshots of LDAP queries (2)

LAB 8: Create Your Enumeration Cheat Sheet

- Duration: 20 minutes | Difficulty: Beginner
- Objective: Document all tools and commands for future reference

Why a Cheat Sheet?

In a real penetration test, you don't have time to look things up.

A personal cheat sheet with commands YOU understand is invaluable!

This becomes your reference for future security assessments.

What to Include

Section 1: Windows Local Enumeration

- Tool: Command Prompt / PowerShell
- Commands:
 - systeminfo - get OS version and patches
 - sc query - list services
 - wmic service get name,pathname,startmode - service paths
 - net user - list users
 - net localgroup Administrators - admin users

Section 2: Windows Remote Enumeration

- Tool: `enum4linux`
- Command: `enum4linux TARGET_IP`
- Tool: `smbclient`
- Command: `smbclient -L //TARGET_IP (list shares)`

Section 3: NetBIOS Discovery

- Tool: `NBTscan`
- Command: `nbtscan TARGET_IP`
- Command: `nbtscan 192.168.1.0/24 (network scan)`

Section 4: Linux Local Enumeration

- Tool: Linux commands

- `uname -a` - OS and kernel version
- `find / -perm -u=s -type f` - SUID binaries
- `systemctl --type=service` - services
- `cat /etc/passwd` - user accounts
- `sudo iptables -L -n` - firewall rules

Section 5: Linux Remote Enumeration

- SNMP: `snmpwalk -c public -v 1 TARGET_IP`
- NFS: `showmount -e TARGET_IP`
- LDAP: `ldapsearch -h TARGET_IP -x -s base`

Lab 8 Deliverable

Create a professional cheat sheet document including:

- All tools used (name, purpose, port)
- Command syntax with examples
- What does the output means (interpretation)
- Common pitfalls and how to avoid them
- Color-coded or formatted for quick reference

It becomes YOUR personal reference tool!

=====

Troubleshooting Guide

Tools Not Found Errors

- Problem: "command not found"
- Solution: `sudo apt-get install [tool-name]`

Permission Denied

- Problem: "Permission denied"
- Solution: Add "sudo" before the command

Connection Refused / Timeout

- Problem: Tool hangs or shows timeout
- Solutions:
 - Check target IP is correct
 - Verify target VM is running
 - Check network connectivity: `ping TARGET_IP`
 - Check firewall rules on target

Enumeration Finds Nothing

- Problem: Tools run but find no services/users
- This is NORMAL! Reasons include:
- Firewall is blocking the port
- Service is not running on target
- Target is well-secured
- Action: Document what you tried and why it failed

LDAP / SNMP / NFS Not Available

- Problem: Port 389/161/2049 not open on target
- Reason: Service not installed/enabled on target
- Action: Try other enumeration methods instead

Quick Reference Table

Tool	Purpose	Port	Command	Target	Info Found
systeminfo	OS info	Local	systeminfo	Local	Version, patches, services
sc query	Services	Local	sc query	Local	Running services
net user	Users	Local	net user	Local	All users
enum4linux	Windows enum	445	enum4linux IP	Windows	Users, groups, shares
smbclient	SMB shares	445	smbclient -L //IP	Windows	Shares and files
nbtscan	NetBIOS	137-139	nbtscan IP	Windows	Computer names
snmpwalk	SNMP query	161	snmpwalk -c public -v 1 IP	Linux	System info, processes
showmount	NFS enum	2049	showmount -e IP	Linux	NFS shares
ldapsearch	LDAP query	389	ldapsearch -h IP -x	Linux	Users, groups
find	SUID bins	Local	find / -perm -u=s	Linux	Privilege escalation

The End!